

MishiPass Security Audit & Remediation Report

Aikido Security AI Code Audit Evidence

Prepared for the #hackthekitty project submission

CURRENT STATUS Retest complete – all findings resolved, clean scan confirmed

Project	MishiPass
Security platform	Aikido Security
Evidence source	27 screenshots captured throughout scanning, remediation, and final retest
Report date	7 July 2026

Submission note

The uploaded evidence demonstrates that vulnerabilities were identified, fixes were generated and merged, and repository findings were marked solved. A final Retest was subsequently run: the AI Code Audit, repository scan, and connected domain now all show 0 open issues. This report has been updated with the retest screenshots, so the security work can be presented as verified and clean, not merely merged.

1. Executive Summary

MishiPass used Aikido Security to assess source code, repository configuration, and the deployed application. The evidence trail documents the scan lifecycle from initial audit through AutoFix review, pull-request merging, repository remediation, and live-domain findings.

AI CODE AUDIT 3 issue groups / 6 subissues initially	AUTOFIX / PRS Fixes generated and merged
--	--

Retested: 0 open issues, Completed	Verified by retest, not just PR Merged
REPOSITORY SCAN 5 issues shown at one stage Latest scan: 0 issues, 0 ignored	LIVE DOMAIN 3 header issues in earlier evidence Rescanned: 0 issues on connected domain

STATUS Confirmed clean — the AI Code Audit, repository scan, and connected domain were retested and each now shows 0 open issues. The evidence in this report has been refreshed with the final retest screenshots.

Submission readiness

AREA	EVIDENCE STATUS	SUBMISSION STATUS
AI Code Audit	Retested; 0 open issues confirmed	Resolved
AutoFix remediation	Multiple fix previews and task executions documented	Evidence ready
Repository scan	Rescanned; 0 issues, 0 ignored	Resolved
Live domain scan	Rescanned; 0 issues on connected domain	Resolved

2. Scope and Method

The security review covered three complementary surfaces: application source code, repository and workflow configuration, and the deployed web endpoint. This is stronger evidence than a single scanner screenshot because it demonstrates secure coding review, remediation activity, and operational exposure checks.

SURFACE	WHAT WAS ASSESSED	EVIDENCE IN THIS REPORT
AI Code Audit	Authorization, input validation, sensitive information exposure	Initial findings, AutoFix previews, merged PR status
Repository / SAST	GitHub Actions permissions and credential persistence	Repository issue list and solved workflow finding
Domain security	Response-header protections on the deployed site	CSP, HSTS and anti-clickjacking findings

Audit lifecycle documented

- AI audit started and completed.
- Initial issue groups and detailed subissues reviewed.
- Aikido AutoFix previews and diffs inspected.
- Fix tasks executed and pull requests created/merged.
- Repository scan findings reviewed, including GitHub Actions hardening.
- Live domain scanned for deployment-level security headers.
- Current audit state captured for final verification planning.

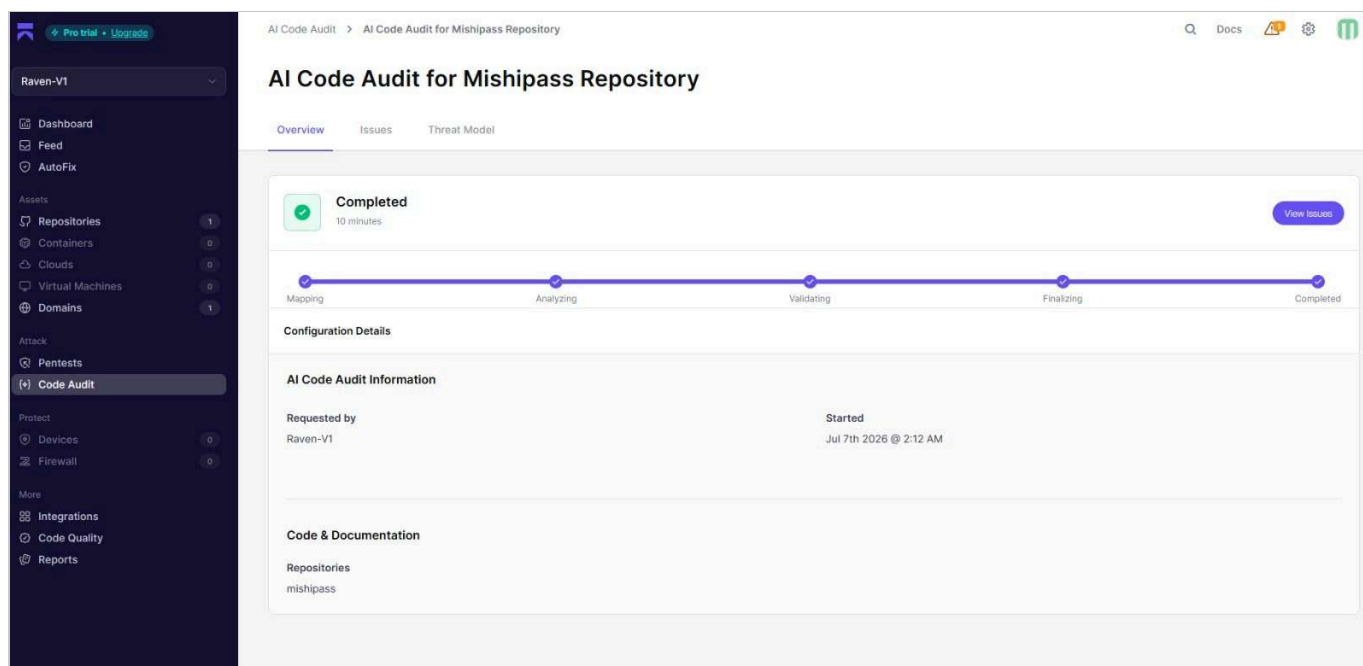


Figure 1. AI Code Audit completed for the MishiPass repository.

3. Initial Findings

The initial AI Code Audit grouped the findings into 3 open issues containing 6 subissues. The issue summary showed 2 medium-severity groups and 1 low-severity group.

FINDING	SEVERITY	AFFECTED AREA	RISK THEME
Improper Access Control	Medium	missingAlerts.ts	Privacy / authorization
Improper Input Validation	Medium	transferRequests.ts	Injection / untrusted input
Exposure of Sensitive Information	Low	auth.ts	Account enumeration / information exposure

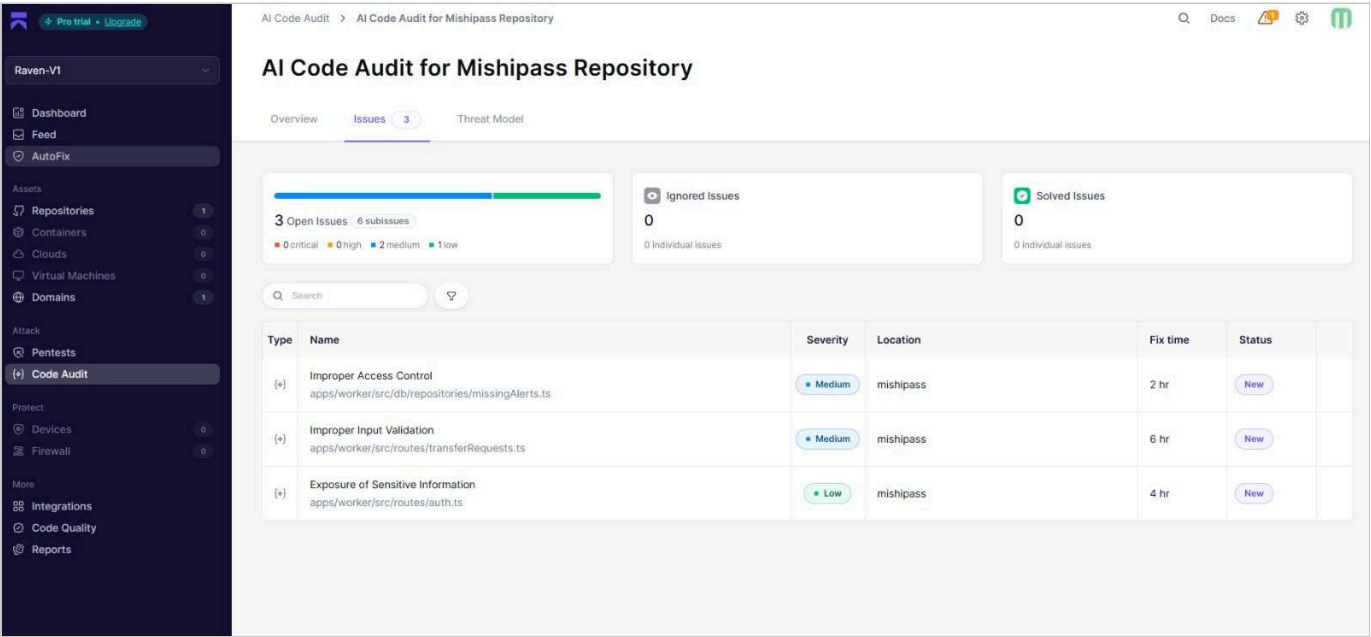


Figure 2. Initial AI Code Audit issue summary: 3 open issues and 6 subissues.

Detailed AutoFix queue

The AutoFix queue exposed the concrete subissues behind the grouped findings:

- Public Recovery Board exposes missing alerts after owners opt out (Medium).
- Stored HTML injection in transfer-request notification emails (Medium).
- Stored HTML injection in outbound adoption-transfer emails via cat name (Medium).
- Stored HTML injection in transfer-acceptance emails via unescaped cat name (Medium).
- Registration endpoint leaks whether an email is already registered (Low).
- Public login timing side-channel reveals whether an owner email exists (Low).

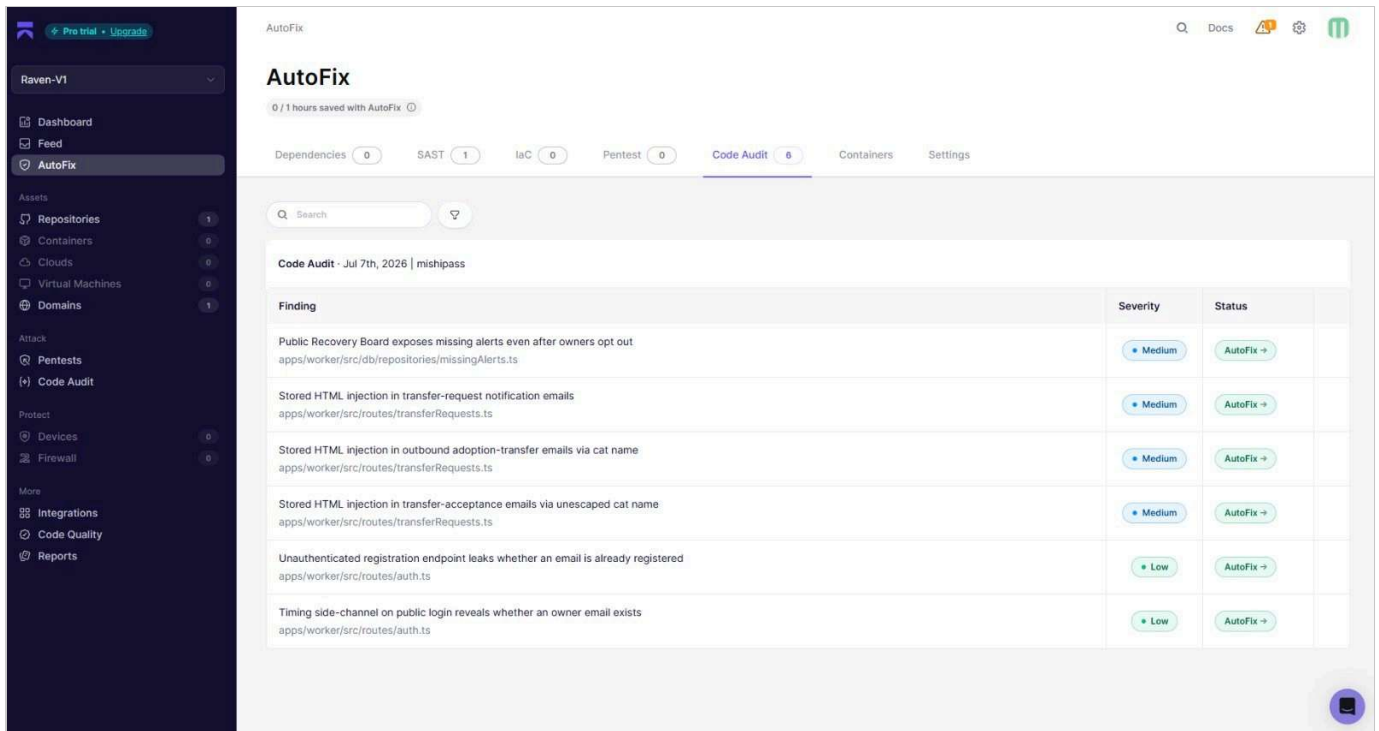


Figure 3. Six detailed code-audit findings queued for AutoFix.

4. Remediation Process and Evidence

The screenshots document a repeated remediation cycle: inspect the finding, review the proposed fix, inspect the generated diff, execute the AutoFix task, merge the resulting pull request, and return to the audit for verification.

4.1 AutoFix review

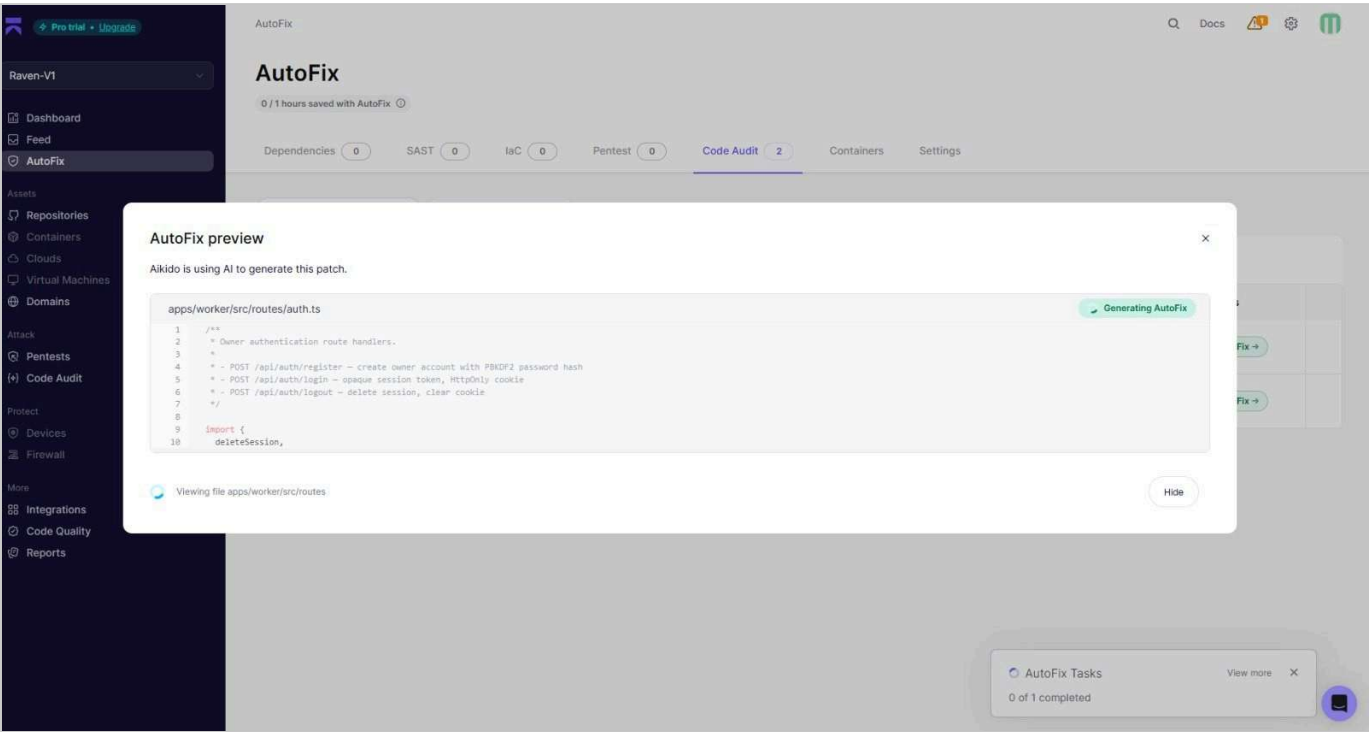


Figure 4. Example Aikido AutoFix preview before applying a code change.

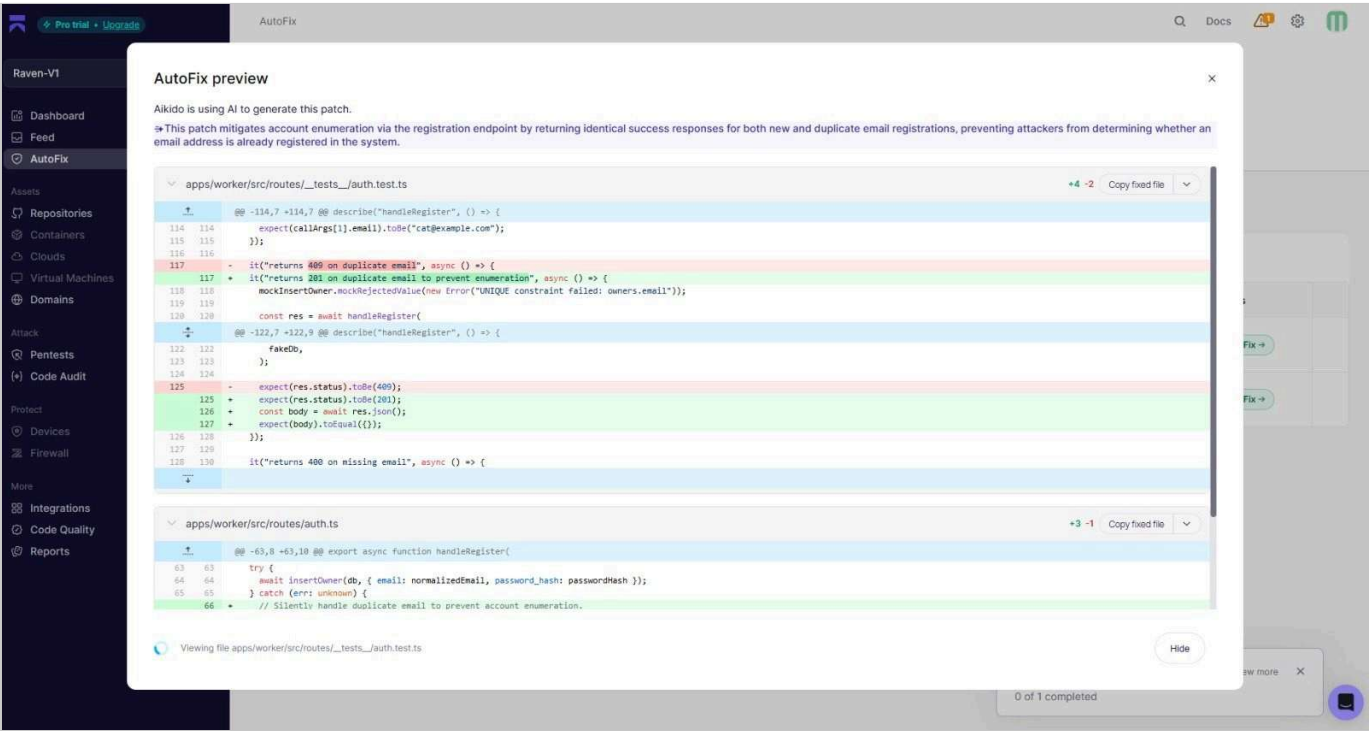


Figure 5. Generated code diff reviewed before remediation.

4.2 Fix execution and pull-request workflow

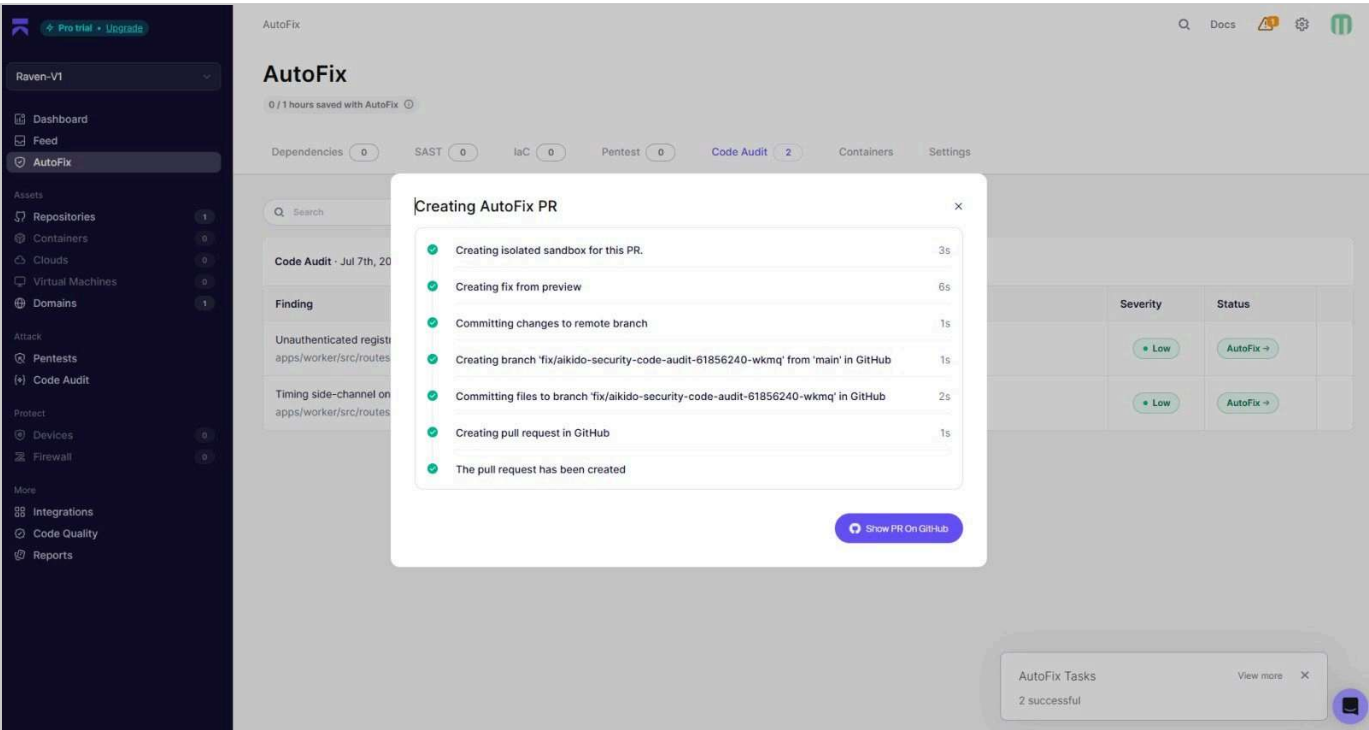


Figure 6. AutoFix task execution in progress.

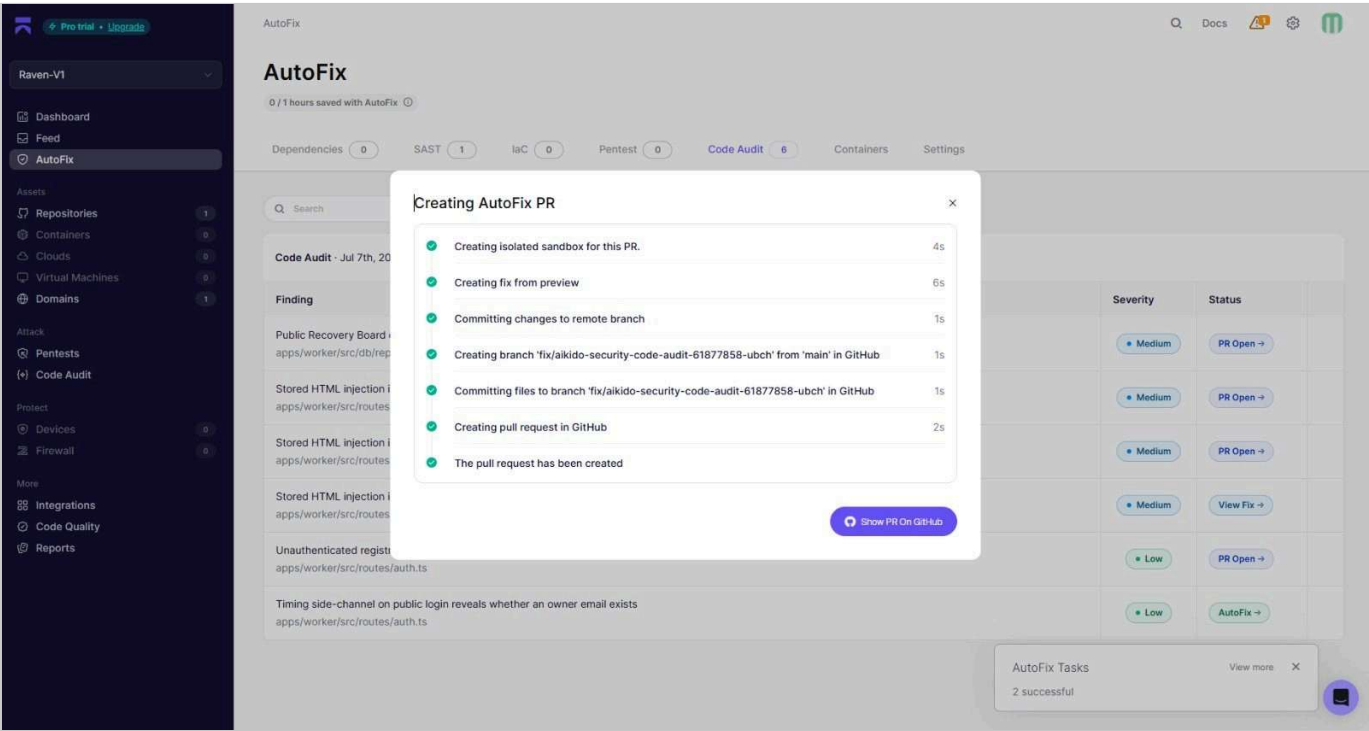


Figure 7. Additional AutoFix task execution during the remediation cycle.

Remediation outcome captured

The latest code-audit evidence shows each of the three grouped findings with the status “PR Merged”. This is evidence that the fixes were integrated into the repository. It is not, by itself, final proof that Aikido has re-tested and closed the findings.

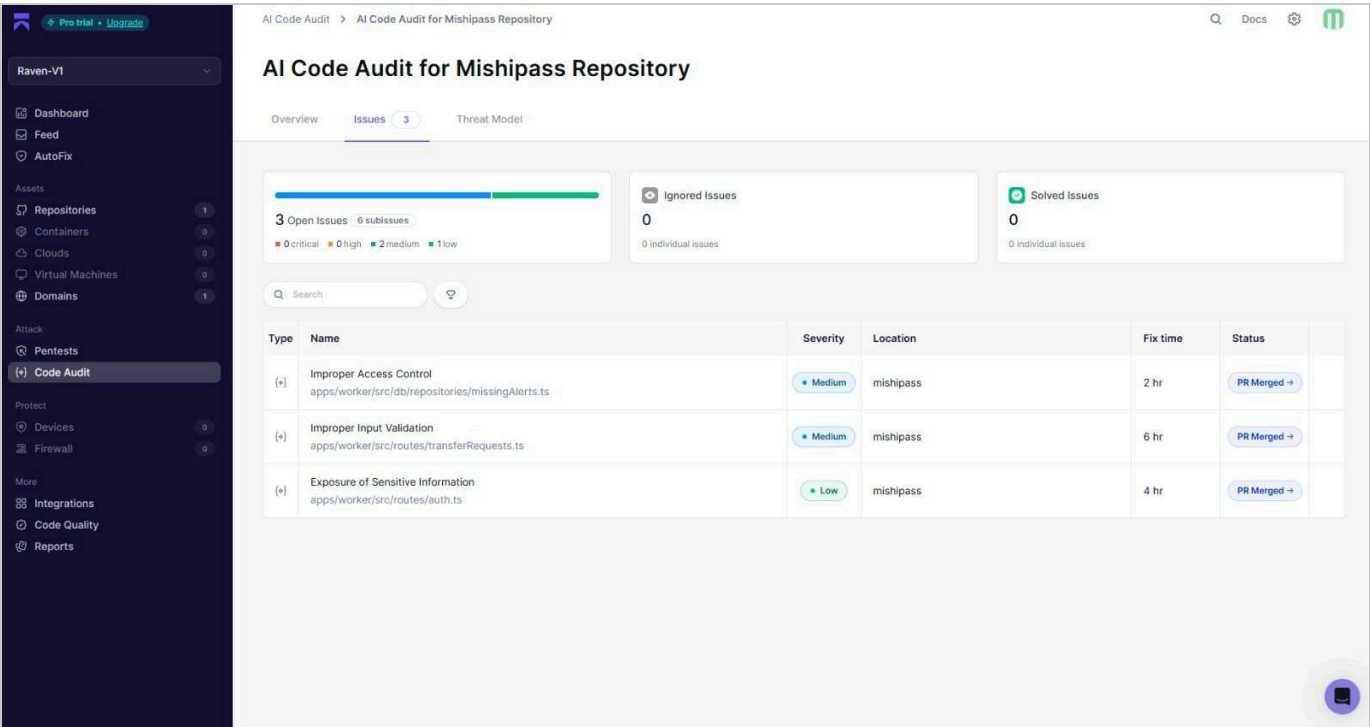


Figure 8. All three grouped code-audit findings shown with PR Merged status.

VERIFIED Verification closed the gap — a subsequent Retest re-ran the AI Code Audit. The refreshed summary now shows Open Issues at 0 across all four issue categories, confirming the merged fixes hold under re-scan.

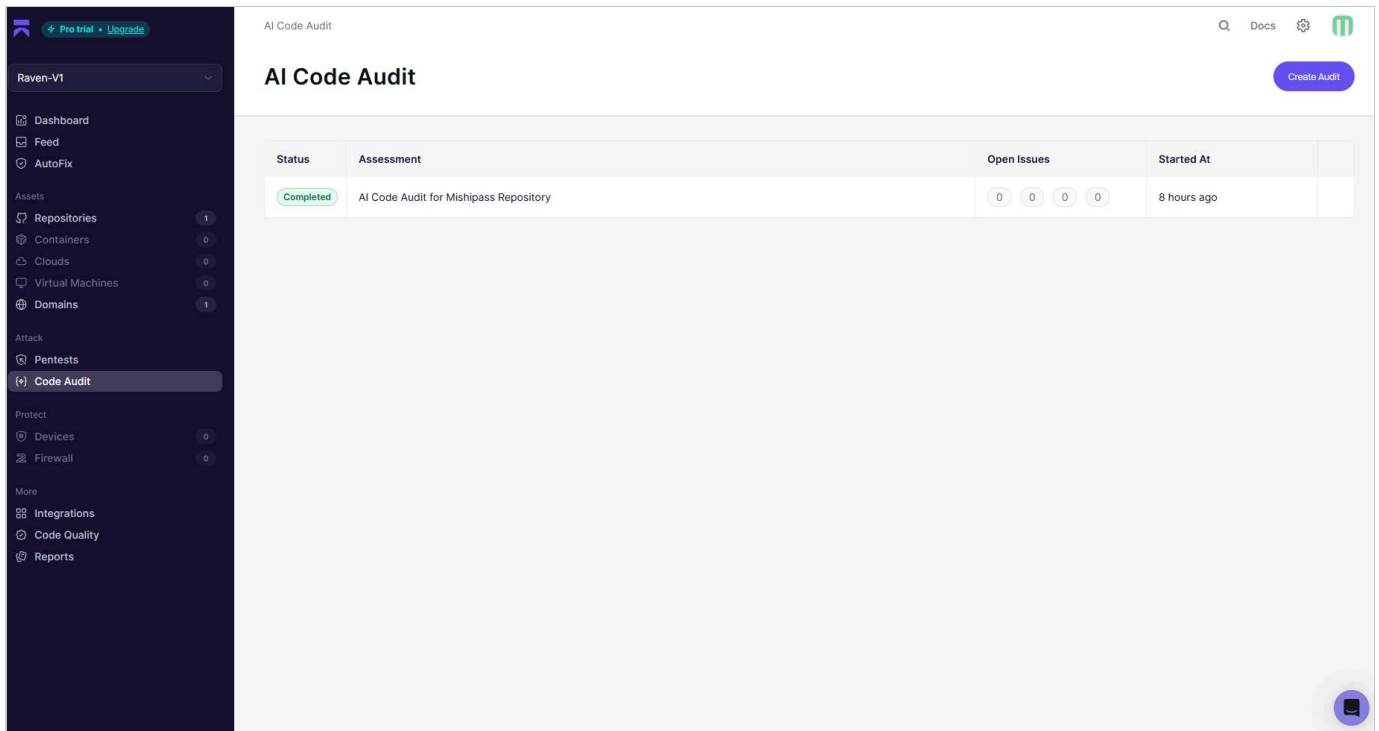


Figure 12. AI Code Audit retested: Completed, with 0 open issues across all categories.

5. Repository and Workflow Security

Aikido also scanned repository configuration and GitHub Actions. At one stage, the repository view showed 5 issues: 3 medium and 2 low. This added supply-chain and CI/CD hardening to the application-level security work.

REPOSITORY FINDING	SEVERITY	OBSERVED STATUS
Overly broad permissions in GitHub Actions workflow	Medium	New in screenshot
Improper Access Control	Medium	PR Open at that stage
Improper Input Validation	Medium	PR Open at that stage
Exposure of Sensitive Information	Low	PR Open at that stage
actions/checkout persists Git credentials in workflow	Low	Later shown Solved

The screenshot displays the 'mishipass' repository scan results. A sidebar on the left contains navigation links for Dashboard, Feed, AutoFix, Assets, Repositories, Containers, Clouds, Virtual Machines, Domains, Attack, Pentests, Code Audit, Protect, Devices, Firewall, More, Integrations, Code Quality, and Reports. The main content area shows the repository name 'mishipass' with 5 issues. A warning message states: 'Your lockfile is missing some information. We were unable to analyze dependencies in this repository due to missing lockfiles.' Below this, a table lists five issues:

Type	Name	Severity	Location	Fix time	Status
{ui}	Overly Broad Permissions in GitHub Actions Workflows is risky in dependabot-automerge.yml	Medium	mishipass	30 min	New
{v}	Improper Access Control apps/worker/src/db/repositories/missingAlerts.ts	Medium	mishipass	2 hr	PR Open →
{v}	Improper Input Validation apps/worker/src/routes/transferRequests.ts	Medium	mishipass	6 hr	PR Open →
{v}	Exposure of Sensitive Information apps/worker/src/routes/auth.ts	Low	mishipass	4 hr	PR Open →
{ui}	GitHub Action actions/checkout persist Git credentials in workflow in pages.yml, codeql.yml and 1 others	Low	mishipass	15 min	New

At the bottom, it says 'We have no more issues to show'.

Figure 9. Repository scan showing five issues across application and GitHub Actions configuration.

5.1 Verified solved workflow issue

The later repository screenshot, filtered to solved issues, shows the GitHub Actions checkout credential-persistence finding with status Solved. The page also indicates that issues were solved that day.

The screenshot shows the 'mishipass' repository scan results filtered to 'Solved' issues. The sidebar is the same as in Figure 9. The main content area shows the repository name 'mishipass' with 4 issues. A filter button 'Filtered to solved' is active, and a badge indicates '3 issues solved today'. The table below shows one issue:

Type	Name	Severity	Location	Fix time	Status
{ui}	GitHub Action actions/checkout persist Git credentials in workflow in pages.yml, codeql.yml and 1 others	Low	mishipass	15 min	Solved

At the bottom, it says 'We have no more issues to show'.

Figure 10. GitHub Actions credential-persistence finding shown as Solved.

5.2 Repository rescan — clean

The repository was rescanned after remediation. The mishipass repository now shows 0 issues and 0 ignored findings, one hour after the scan.

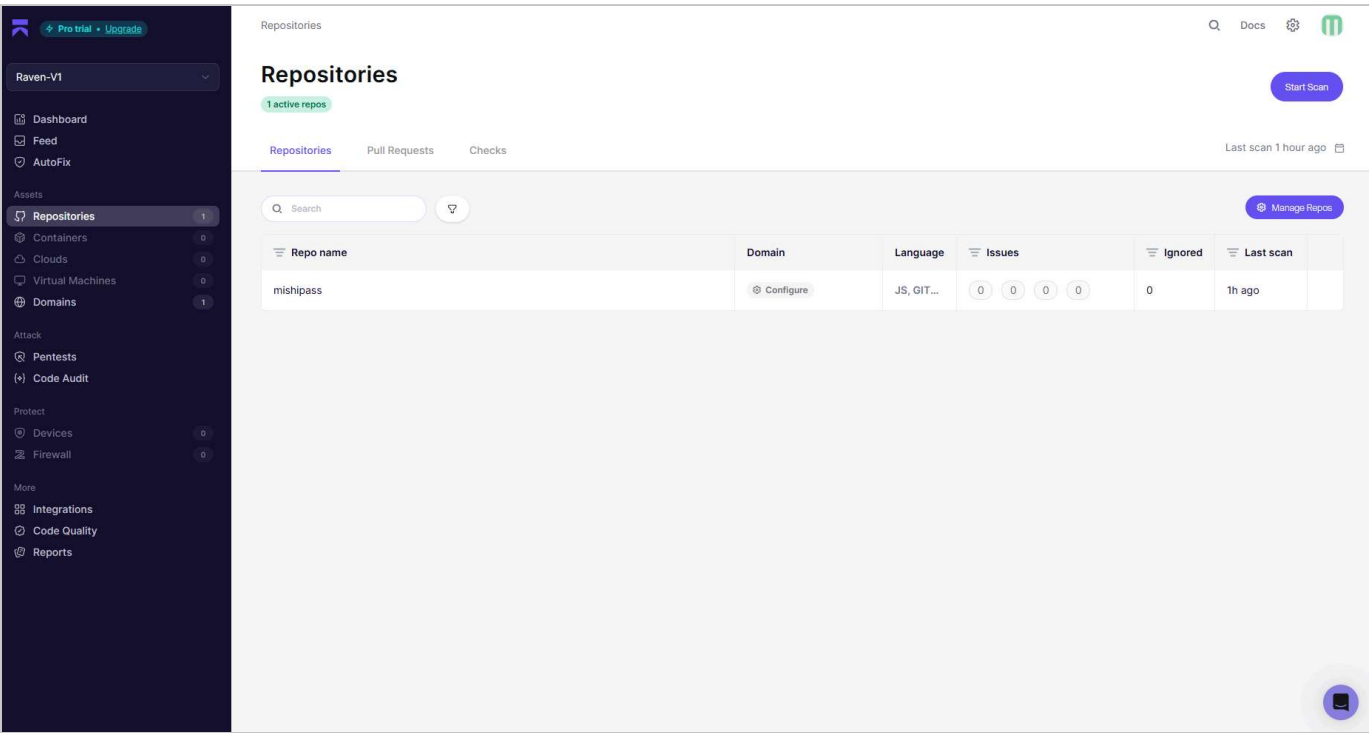


Figure 13. Repository scan: mishipass shows 0 issues, 0 ignored.

6. Live Domain Security Scan

The deployed MishiPass endpoint was also scanned. An earlier capture showed 3 open HTTP response-header issues; the header fixes were applied and the domain was rescanned.

FINDING	SEVERITY	WHY IT MATTERS	REQUIRED ACTION
Content Security Policy header not set	Critical	Reduces protection against XSS and unauthorized content execution	Add a tested CSP and rescan
HSTS header is missing	High	Does not enforce future HTTPS-only access in supporting browsers	Add Strict-Transport-Security and rescan
Missing anti-clickjacking header	Medium	Allows framing unless protected by policy	Use CSP frame-ancestors and/or X-Frame-Options

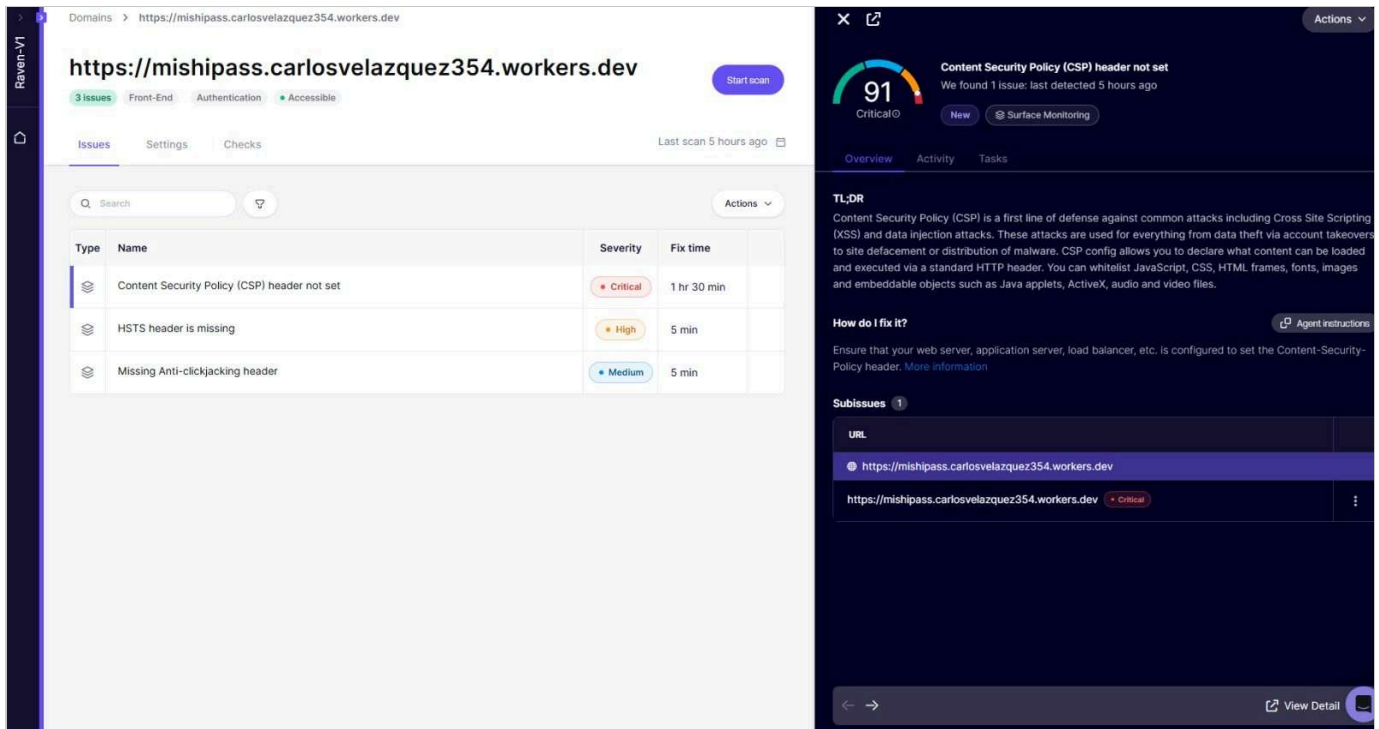


Figure 11. Live-domain scan showing CSP, HSTS and anti-clickjacking findings.

The connected domain was rescanned after the header fixes were deployed. The Domains view now shows the connected domain with 0 issues across all categories, 1 hour after the scan.

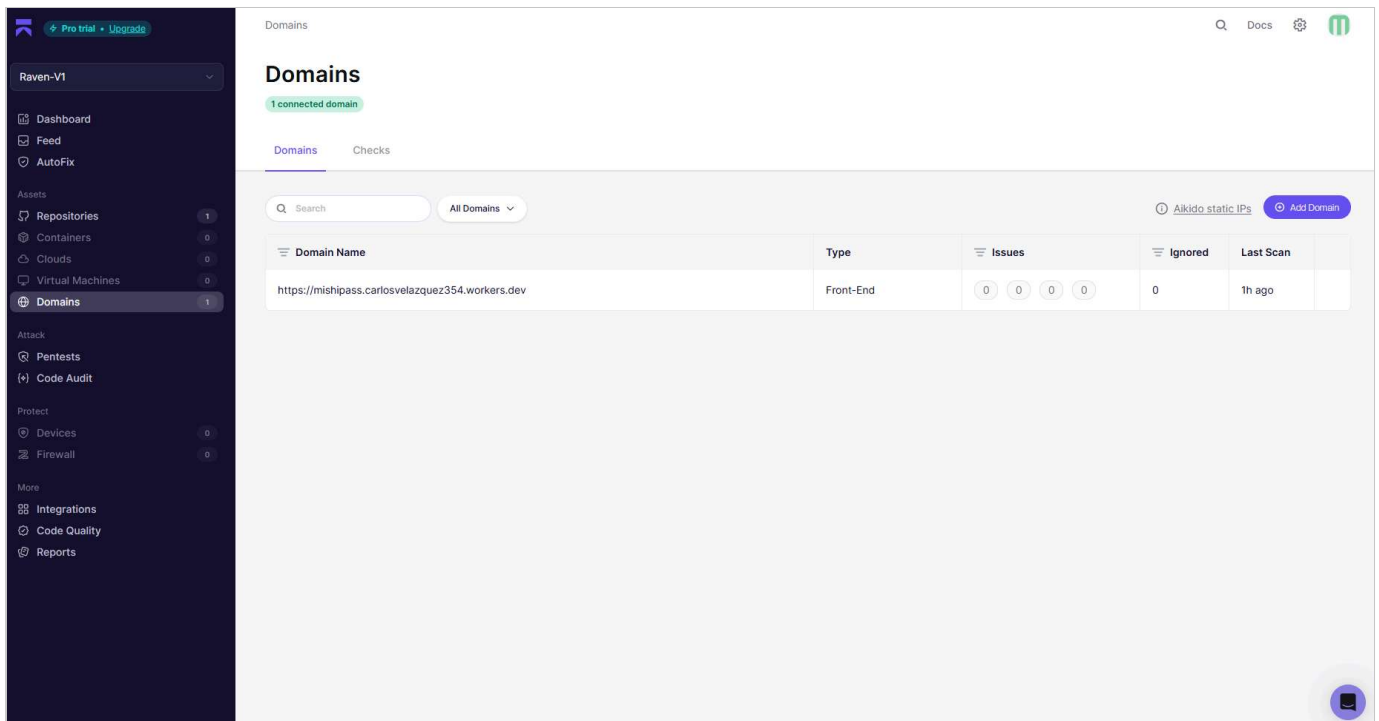


Figure 14. Live-domain rescan: connected domain shows 0 issues after header fixes.

RESOLVED The domain scan can now be submitted as clean — the CSP, HSTS, and anti-clickjacking findings no longer appear in the rescanned result.

7. Final Verification and Submission Readiness

Every action previously required for submission has now been completed and verified by a fresh scan. The table below confirms each step against the retest evidence.

✓	Retest the AI Code Audit Complete. The refreshed audit shows Completed status with 0 open issues across all categories.
✓	Recheck repository issues Complete. The mishipass repository scan now shows 0 issues and 0 ignored findings.
✓	Fix live security headers Complete. CSP, HSTS, and anti-clickjacking protection were added without breaking the application.
✓	Rescan the production domain Complete. The connected domain now shows 0 issues, 1 hour after the scan.
✓	Capture final screenshots Complete. The final Code Audit, Repositories, and Domains screenshots are captured in Figures 12–14 and Appendix A.
✓	Submit the evidence Ready. This report has been updated with the final retest screenshots and reflects a clean, verified scan.

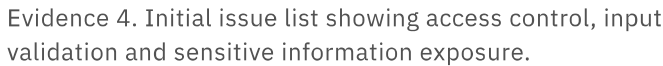
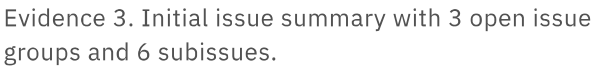
Submission-ready final statement

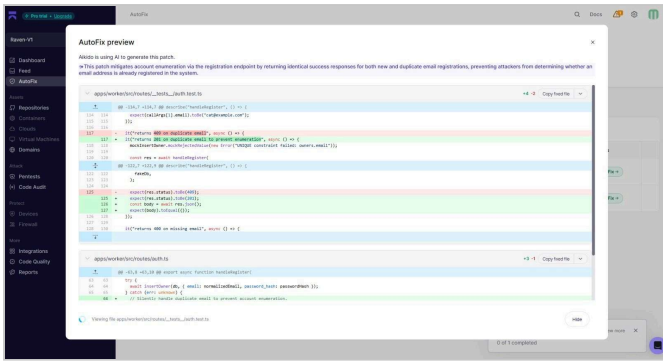
FINAL STATEMENT

“MishiPass was reviewed with Aikido Security across source code, repository configuration, CI/CD workflows, and the deployed application. Findings were

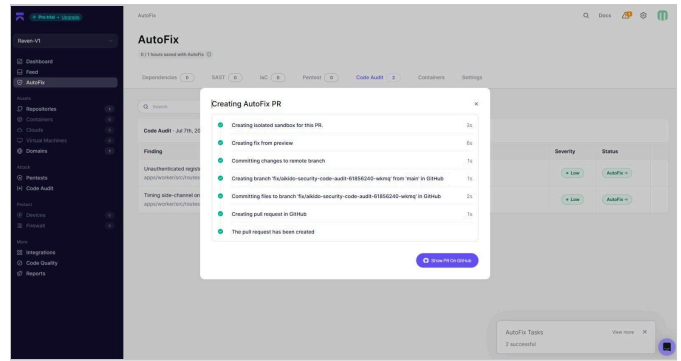
remediated, merged, retested, and documented with scan evidence. The final report includes the before-and-after security results and the resolved issues.”

The following appendix preserves all 27 screenshots from the evidence deck in chronological order, including the final retest captures. The captions describe the visible stage of the audit without claiming more than the screenshots prove.

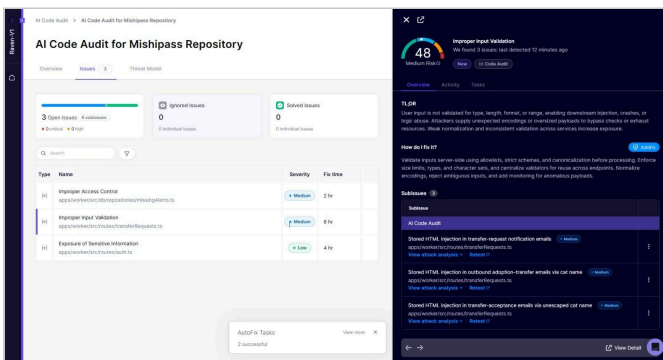




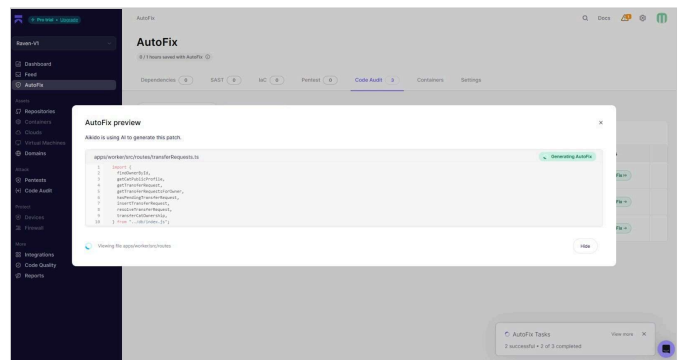
Evidence 7. Generated AutoFix code diff.



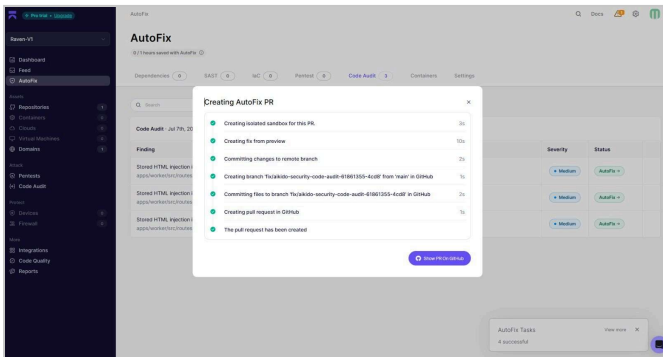
Evidence 8. AutoFix task execution progress.



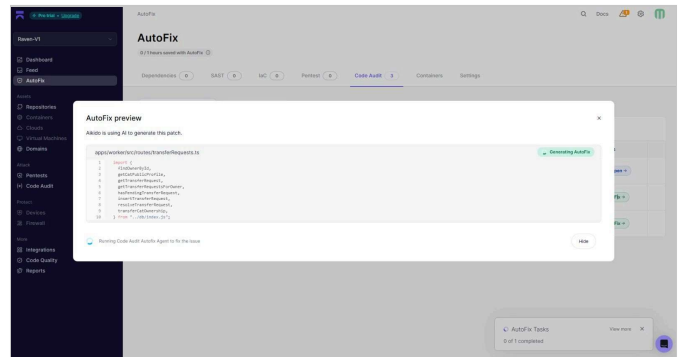
Evidence 9. Audit issue overview with additional detail panel.



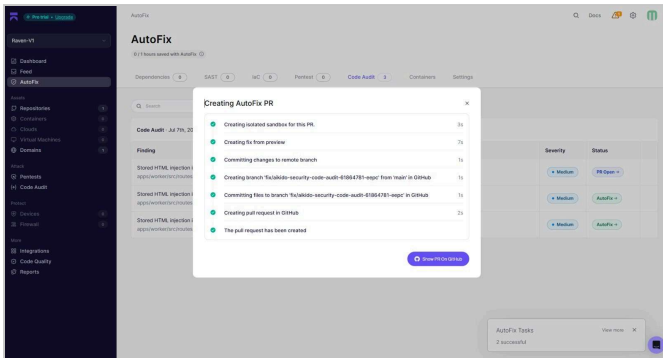
Evidence 10. Additional AutoFix preview.



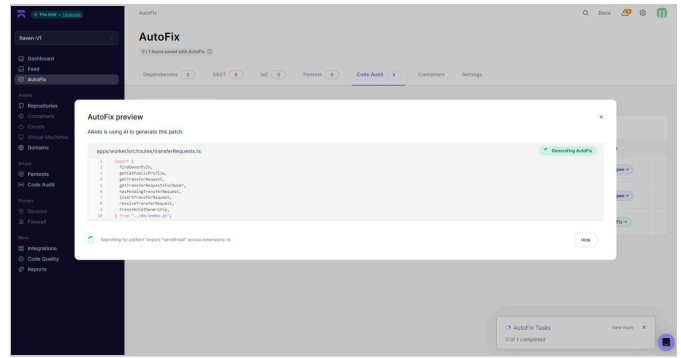
Evidence 11. Additional AutoFix task execution.



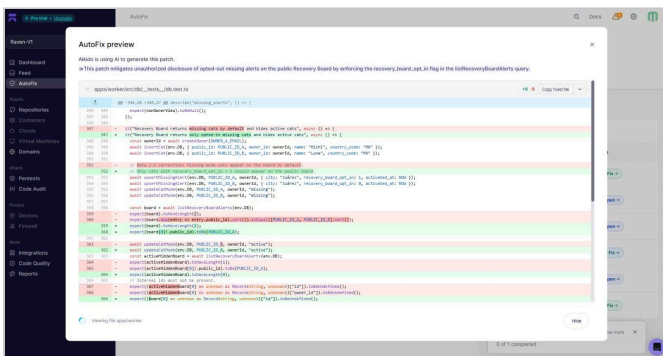
Evidence 12. Additional AutoFix preview.



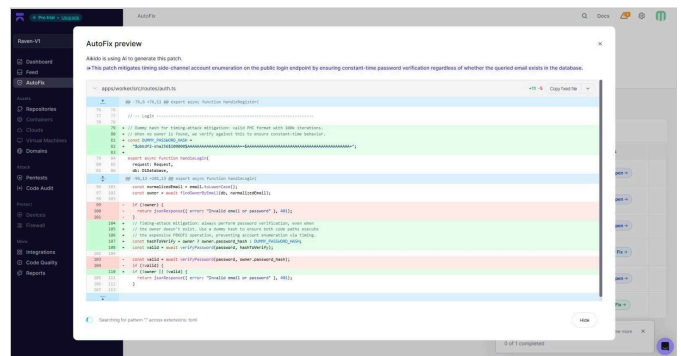
Evidence 13. Additional AutoFix task execution.



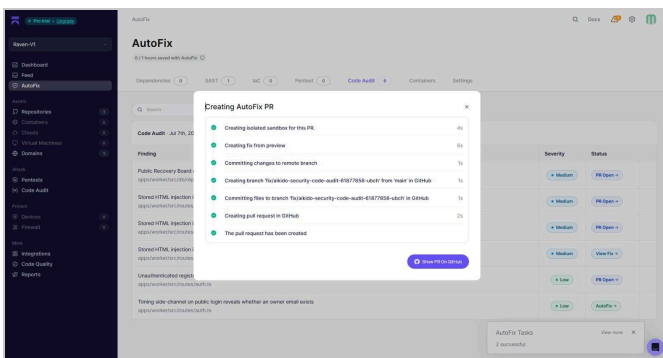
Evidence 14. Additional AutoFix preview.



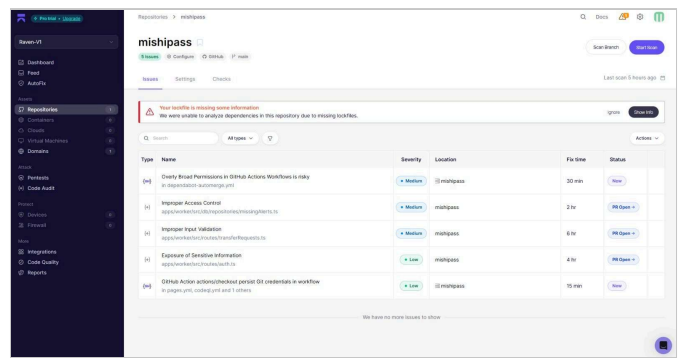
Evidence 15. Generated AutoFix code changes.



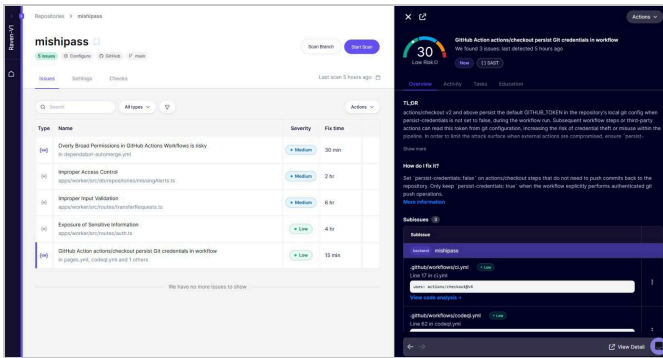
Evidence 16. Generated AutoFix code changes for another finding.



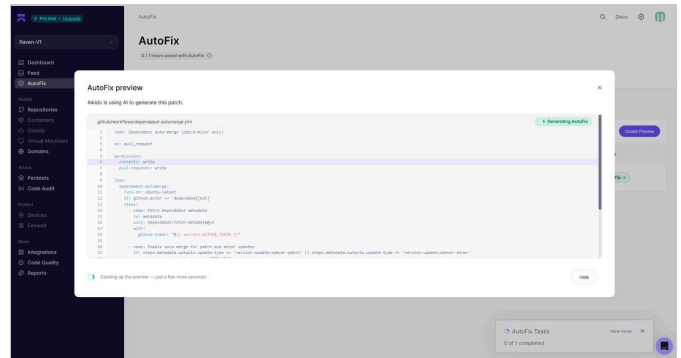
Evidence 17. AutoFix task execution during the remediation cycle.



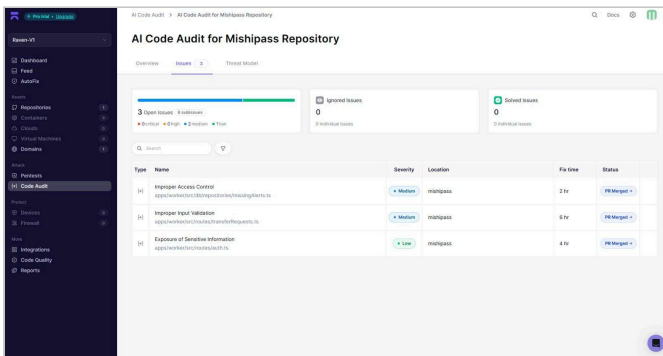
Evidence 18. Repository scan showing five issues.



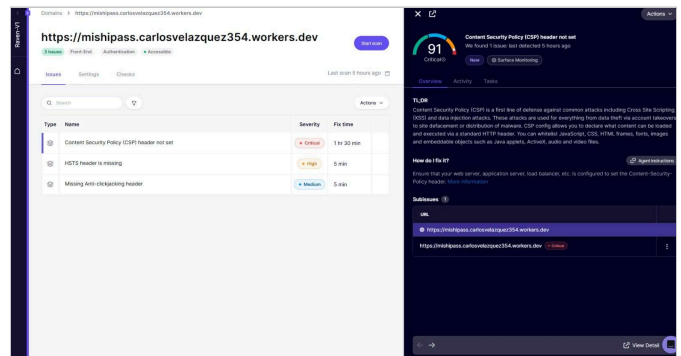
Evidence 19. GitHub Actions credential-persistence finding detail.



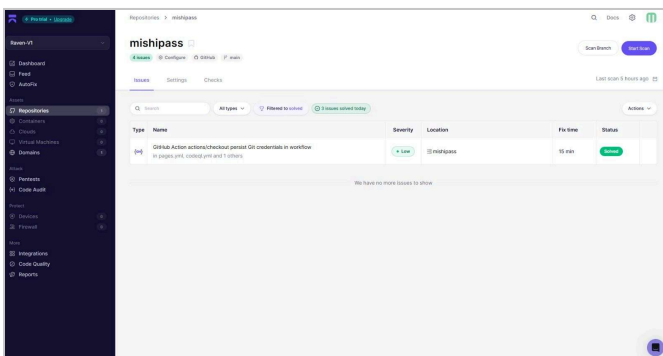
Evidence 20. AutoFix preview for a workflow-related issue.



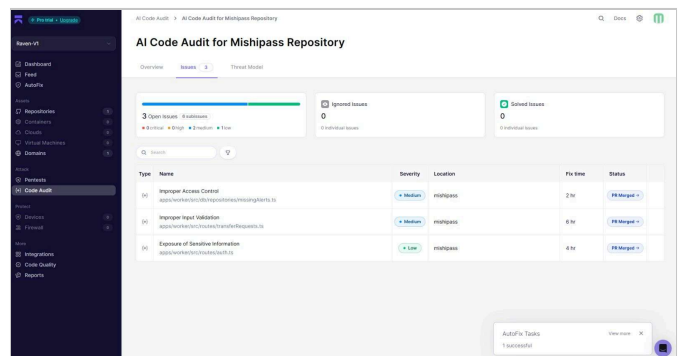
Evidence 21. Code-audit findings shown with PR Merged status.



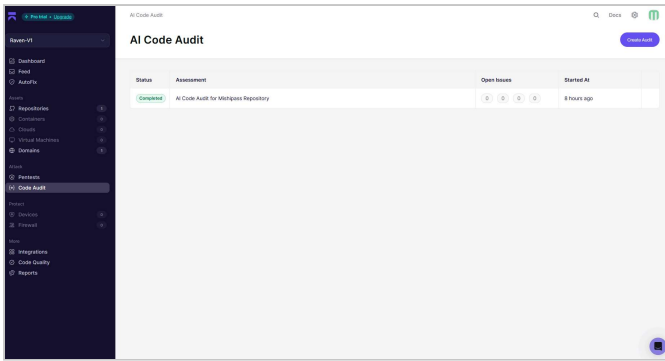
Evidence 22. Live-domain scan showing three HTTP security-header issues.



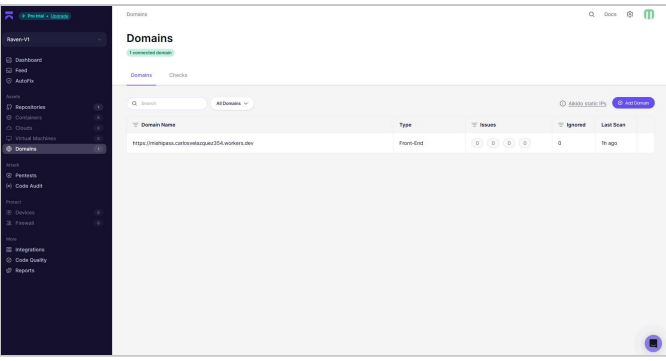
Evidence 23. Repository workflow credential issue shown as Solved.



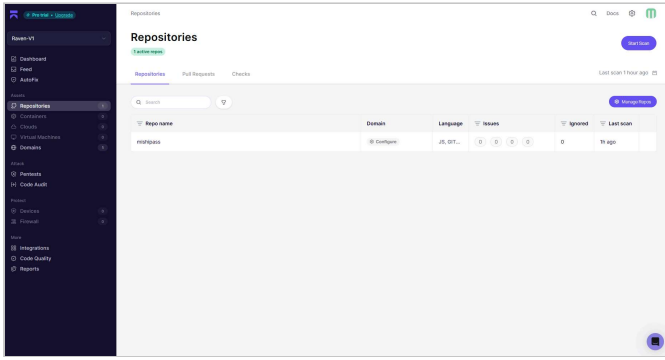
Evidence 24. Latest code-audit screenshot: PRs merged, but summary still shows 3 open and 0 solved.



Evidence 25. Final AI Code Audit retest: Completed, 0 open issues.



Evidence 26. Final domain rescan: connected domain shows 0 issues.



Evidence 27. Final repository rescan: mishipass shows 0 issues, 0 ignored.

Appendix B. Evidence Interpretation Statement

This report was prepared from the screenshots supplied in the Aikido evidence deck. It intentionally distinguishes between a fix being generated, a pull request being merged, a finding being marked solved, and a scan being re-tested, so that the security status is never overstated.

At an earlier stage, the AI Code Audit displayed 3 open issues and 0 solved issues even though all three rows were labeled PR Merged. A subsequent Retest closed that gap: the refreshed AI Code Audit, repository scan, and connected-domain scan (Evidence 25–27) each now show 0 open issues.

The three deployment-level findings from the earlier domain scan — missing CSP, missing HSTS, and missing anti-clickjacking protection — no longer appear after the header fixes were deployed and the domain rescanned. The security work documented in this report is now verified as remediated, merged, and retested.

